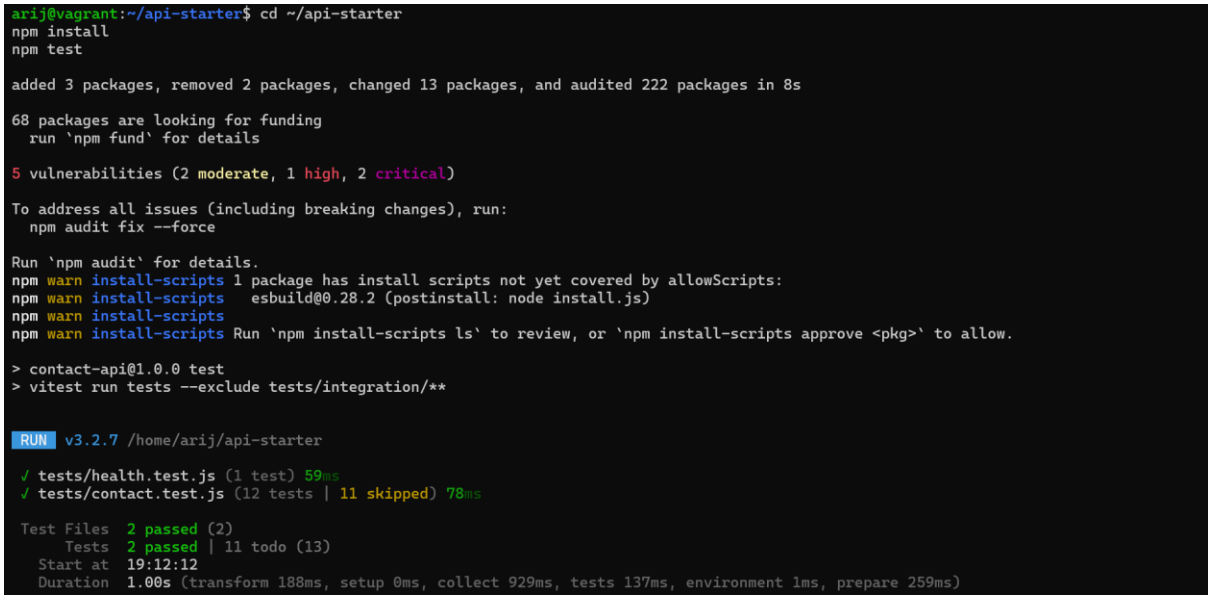
TP8 : API Express sécurisée et testée (Zod, Helmet, rate limiting, Vitest)

Environnement du TP :



Partie 1 : OWASP API Security Top 10

Risque OWASP	***Concerne notre API ?***	***Mesure dans ce TP***
API1: Broken Object Level Authorization (BOLA)	***Non (pour l'instant)***	***Aucune route ne permet de lire un objet par son ID sans vérifier le propriétaire. (Attention : si on ajoute GET /api/contact/:id, il faudra de l'authentification).***
API2: Broken Authentication	***Non (pour l'instant)***	***Le formulaire de contact est public. (Si on ajoutait une route admin pour lire les messages, il faudrait une authentification forte).***
API3: Broken Object Property Level Authorization	***Oui***	***.strict() dans Zod refuse les champs non déclarés (empêche le Mass Assignment, ex: envoyer isAdmin: true).***

Risque OWASP	*Concerne notre API ?*	*Mesure dans ce TP*
API4: Unrestricted Resource Consumption	*Oui*	*express-rate-limit (5 req/min) et express.json({ limit: '10kb' }) (taille max du corps de la requête).*
API5: Broken Function Level Authorization	*Non*	*Pas de fonction d'administration dans l'API actuelle.*
API6: Unrestricted Access to Sensitive Business Flows	*Oui*	*Le formulaire peut être spammé. La mesure est le rate limiting (API4) qui limite les dégâts.*
API7: Server Side Request Forgery (SSRF)	*Non*	*L'API ne demande pas d'URL à l'utilisateur pour faire des requêtes serveur.*
API8: Security Misconfiguration	*Oui*	*Helmet (sécurise les headers), app.disable("x-powered-by"), et le errorHandler qui ne divulgue plus la stack trace (remplacée par une erreur générique 500).*
API9: Improper Inventory Management	*Non*	*Une seule version de l'API est déployée dans ce TP.*
API10: Unsafe Consumption of APIs	*Non*	*L'API ne consomme pas d'API tierces (pas de fetch ou axios vers l'extérieur).*

Partie 2 : Validation et gestion des erreurs

1. Créer le schéma de validation Zod

```
arij@vagrant:~/api-starter$ nano src/schemas/contact.js
arij@vagrant:~/api-starter$ nano src/middlewares/validate.js
arij@vagrant:~/api-starter$ nano src/routes/contact.js
arij@vagrant:~/api-starter$ nano src/middlewares/errorHandler.js
arij@vagrant:~/api-starter$ nano src/app.js
```

2. Tester :

```
arij@vagrant:~/api-starter$ npm test

> contact-api@1.0.0 test
> vitest run tests --exclude tests/integration/**


 RUN  v3.2.7 /home/arij/api-starter

 ✓ tests/health.test.js (1 test) 79ms
 ✓ tests/contact.test.js (12 tests | 11 skipped) 100ms

 Test Files  2 passed (2)
      Tests  2 passed | 11 todo (13)
   Start at  19:28:44
   Duration  1.15s (transform 186ms, setup 0ms, collect 1.17s, tests 179ms, environment 1ms, prepare 230ms)
```

Partie 3 : Durcissement http :

1.Installer les dépendances

```
arij@vagrant:~/api-starter$ npm install helmet express-rate-limit

changed 2 packages, and audited 222 packages in 3s

68 packages are looking for funding
  run `npm fund` for details

5 vulnerabilities (2 moderate, 1 high, 2 critical)

To address all issues (including breaking changes), run:
  npm audit fix --force

Run `npm audit` for details.
npm warn install-scripts 1 package has install scripts not yet covered by allowScripts:
npm warn install-scripts   esbuild@0.28.2 (postinstall: node install.js)
npm warn install-scripts
npm warn install-scripts Run `npm install-scripts ls` to review, or `npm install-scripts approve <pkg>` to allow.
```

2.Configurer src/app.js, src/routes/contact.js

```
arij@vagrant:~/api-starter$ nano src/routes/contact.js
arij@vagrant:~/api-starter$ nano src/app.js
arij@vagrant:~/api-starter$
```

3. Tester :

```
arij@vagrant:~/api-starter$ npm start

> contact-api@1.0.0 start
> node src/server.js

contact-api écoute sur le port 4000
```

```
arij@vagrant:~$ curl -I http://localhost:4000/api/health
HTTP/1.1 200 OK
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-DNS-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-XSS-Protection: 0
Content-Type: application/json; charset=utf-8
Content-Length: 15
ETag: W/"f-VaSQ4oDUiZblZNAEkkN+sX+q3Sg"
Date: Thu, 29 Oct 2026 19:41:15 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

4. Teste le Rate Limiting

```
arij@vagrant:~$ for i in $(seq 1 7); do
  curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:4000/api/contact \
    -H 'Content-Type: application/json' \
    -d '{"name":"Ada","email":"ada@example.com","message":"Bonjour le monde"}'
done
500
500
500
500
500
429
429
arij@vagrant:~$
```

Partie 4 : Tests de routes et cas négatifs

Test1

```
arij@vagrant:~/api-starter$ npm test

> contact-api@1.0.0 test
> vitest run tests --exclude tests/integration/**


 RUN  v3.2.7 /home/arij/api-starter

 ✓ tests/health.test.js (1 test) 112ms
 ✓ tests/contact.test.js (12 tests) 240ms

 Test Files  2 passed (2)
      Tests  13 passed (13)
   Start at  19:49:35
   Duration  1.20s (transform 156ms, setup 0ms, collect 1.01s, tests 352ms, environment 1ms, prepare 234ms)

arij@vagrant:~/api-starter$
```

Test2 :

```
arij@vagrant:~/api-starter$ npm run test:coverage

> contact-api@1.0.0 test:coverage
> vitest run tests --exclude tests/integration/** --coverage


 RUN  v3.2.7 /home/arij/api-starter
      Coverage enabled with v8

 ✓ tests/health.test.js (1 test) 68ms
 ✓ tests/contact.test.js (12 tests) 249ms

 Test Files  2 passed (2)
      Tests  13 passed (13)
   Start at  19:50:52
   Duration  1.74s (transform 197ms, setup 0ms, collect 1.21s, tests 317ms, environment 1ms, prepare 274ms)

 % Coverage report from v8
----------------------|---------|----------|---------|---------|-------------------
File                  | % Stmts | % Branch | % Funcs | % Lines | Uncovered Line #s
----------------------|---------|----------|---------|---------|-------------------
All files             |   71.69 |     87.5 |   63.63 |   71.69 |
 src                  |   38.63 |    33.33 |   33.33 |   38.63 |
  app.js              |   94.44 |      100 |     100 |   94.44 | 18
  migrate.js          |       0 |        0 |       0 |       0 | 1-23
  server.js           |       0 |        0 |       0 |       0 | 1-7
 src/middlewares      |   95.23 |     92.3 |     100 |   95.23 |
  errorHandler.js     |   89.47 |     87.5 |     100 |   89.47 | 4-5
  validate.js         |     100 |      100 |     100 |     100 |
 src/repositories     |   51.51 |      100 |      50 |   51.51 |
  contactRepository.js|   51.51 |      100 |      50 |   51.51 | 5-19,32
 src/routes           |     100 |      100 |     100 |     100 |
  contact.js          |     100 |      100 |     100 |     100 |
```

Partie 5 : Intégration avec PostgreSQL et migrations

1.Configurer et démarrer PostgreSQL

```
arij@vagrant:~/api-starter$ set -a; . ./.env; set +a
arij@vagrant:~/api-starter$
arij@vagrant:~/api-starter$ docker compose up -d --wait
[+] Running 13/13
 ✔db Pulled                                                                    43.0s
   ✔9098654d3377 Pull complete                                                  0.4s
   ✔d5bf1ad711f7 Pull complete                                                  0.4s
   ✔dddde5442af4 Pull complete                                                  4.4s
   ✔fa5e490e3893 Pull complete                                                  1.2s
   ✔694a01b64034 Pull complete                                                 39.5s
   ✔7a82a00c713d Pull complete                                                 39.6s
   ✔7b229517ed22 Pull complete                                                  4.2s
   ✔d6e09b1bfe5f Pull complete                                                  1.2s
   ✔e018eb860c5e Pull complete                                                  1.2s
   ✔f5e975d661d7 Pull complete                                                  1.2s
   ✔112f26c8faed Download complete                                              0.0s
   ✔e22336567ca8 Download complete                                              0.1s
[+] Running 2/2
 ✔Network contact-api_default  Created                                          0.1s
 ✔Container contact-api-db-1   Healthy                                          7.0s
```

2. Appliquer les migrations

```
arij@vagrant:~/api-starter$ npm run migrate

> contact-api@1.0.0 migrate
> node src/migrate.js

migration appliquée : 001_create_contacts.sql
arij@vagrant:~/api-starter$ npm run migrate

> contact-api@1.0.0 migrate
> node src/migrate.js
```

3. Créer une nouvelle migration (Index)

```
arij@vagrant:~/api-starter$ nano migrations/002_add_contacts_email_index.sql
arij@vagrant:~/api-starter$ npm run migrate

> contact-api@1.0.0 migrate
> node src/migrate.js

migration appliquée : 002_add_contacts_email_index.sql
arij@vagrant:~/api-starter$
```

4. Compléter le test d'intégration :

```
arij@vagrant:~/api-starter$ npm run test:integration

> contact-api@1.0.0 test:integration
> vitest run tests/integration


 RUN  v3.2.7 /home/arij/api-starter

 ✓ tests/integration/contact.int.test.js (1 test) 188ms
   ✓ Intégration Contact API (PostgreSQL) > enregistre un contact dans la vraie base de données 160ms

 Test Files  1 passed (1)
      Tests  1 passed (1)
   Start at  20:06:16
   Duration  1.08s (transform 139ms, setup 0ms, collect 449ms, tests 188ms, environment 0ms, prepare 135ms)
```

5. Test manuel avec curl

```
arij@vagrant:~$ curl -X POST http://localhost:4000/api/contact \
  -H "Content-Type: application/json" \
  -d '{"name": "Manuel", "email": "manuel@example.com", "message": "Test manuel de la base"}'
{"status":"ok"}acurl -X POST http://localhost:4000/api/contact \0/api/contact \
  -H "Content-Type: application/json" \
  -d '{"name": "Robert'\''); DROP TABLE contacts;--", "email": "hacker@example.com", "message": "test injection"}'
{"status":"ok"}arij@vagrant:~$
```